

Agent 扩展授权中的 artifact identity drift

Goose v1.45.0 Case Study

authorization-reference drift

同一条 `package@latest`:
检查时指向 A，启动时跑成了 B。

配置没有改；Auto 模式下，全程没有批准界面。

证据

D1 盲发现 • R1-2 / R1-3 两次按协议复现

R1-1 看到同样结果，但有协议偏差，不计入符合协议的重复。

进度

R1 / R2 已完成

R3 尚未执行

虚拟机已休眠；恢复后重新检查实验环境。

研究问题

「代码是正版的」 ≠ 「被授权执行的那一版」

<code>extension name</code>	<code>mutable selector</code>	<code>exact version</code>	<code>content digest</code>	<code>RuntimeArtifact</code>
扩展名	可变选择器 @latest	精确版本号	内容摘要（当前缺失）	实际执行的字节

核心问题：系统授权的对象，与最终执行的具体字节，是否是同一个对象？

Goose 内部机制

source root-cause audit · read-only · v1.45.0 @ 4dc0420f...

Goose 进程内（已审计控制点）



配置保存的是启动配方，不是 artifact 身份
04 · 机制

ExtensionConfig 没有 digest / checksum 字段

Goose 进程之外

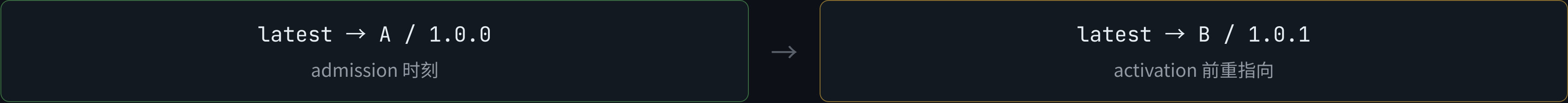


DRIFT
漂移发生在
authorization
reference
与 RuntimeArtifact
之间——
名字不变，字节已换

npx 的解析发生在 Goose 进程之外、所有控制点之后
PRIVATE — Research Discussion

受控实验设计

registry 状态



Goose 配置文本

package@latest
全程一字未改（运行前后哈希相同）

最终执行由多通道交叉确认：**artifact 自报（serverInfo）** • **effect 文件** • **registry 访问日志** • **进程祖先链**——各通道互不依赖。

- 本地 loopback 测试 registry
- 良性 A / B artifact
- 隔离 effects 目录
- 无真实用户 / 凭据 / 公开恶意包

D1：唯一的盲发现

admission 观察到 A (1.0.0)

activation 实际执行 B (1.0.1)

全程 0 次批准提示 (Auto 模式)

Level 1

顺序现象

init 效应早于首次工具调用 (D1 间隔约 9.85 s)

Level 2 ✓

授权引用与执行 artifact 漂移

admission 观测 $A \wedge \text{RuntimeArtifact} = B \wedge \text{grant}$ 仅绑定可变 selector

Level 3 ✕

需要 `SystemCheckedOrBound(A)` 的证据

`system_bound_digest = absent`，四轮一致——当前没有证据

定性上限：不是 TOCTOU，不是任意代码执行——结论止于 authorization-reference drift。

源码根因

多个安全环节，共用**同一个弱身份**（名字）

ExtensionConfig 无 digest 字段
agents/extension.rs:176 · 全文检索 0 命中

ToolPermissionRecord 绑定 tool_name
permission/permission_store.rs:12

OSV 检查按包名查询
agents/extension_malware_check.rs:154

discovery 只暴露 name / description
agents/extension_manager.rs:1998

CanonicalGrant 保存 cmd / args
配置与权限记录合起来仍无 artifact 字段

@latest 被显式归约为 version: None
extension_malware_check.rs:99

正确表达：Goose **确实有安全检查**（OSV 对恶意软件筛查有效），但**检查、授权和执行没有共同绑定到同一个最终 artifact**——三者正交于本研究的失效模式。

R1：可重复性结果

轮次	认识论地位	admission	RuntimeArtifact	Level	协议状态
D1	preregistered（盲）	A 1.0.0	canary-B	L2	idea/48（已终止于 D1）
R1-1	post-discovery，A5.6 并发偏差	A 1.0.0	canary-B	L2	不计入 conforming
R1-2	post-discovery confirmatory	A 1.0.0	canary-B	L2	conforming replicate #1（rig v8）
R1-3	post-discovery confirmatory	A 1.0.0	canary-B	L2	conforming replicate #2（rig v9）

总结上限：一次盲发现，加两次前瞻符合协议的重复。不得称 $N = 3$ ，不得把四轮合并为一个重复计数。

R2: exact-version 阴性对照

R1 组 · package@latest (4 轮)

dist-tag 重指向	A → B (已执行)
RuntimeArtifact	B (漂移发生)
level-2	成立

R2 组 · package@1.0.0 (2 轮)

dist-tag 重指向	A → B (同样执行)
RuntimeArtifact	A (漂移未发生)
level-2	未发生

R2 每轮 五条独立证据确认执行 A:

effect 文件 canary-A

安装树 version 1.0.0

registry tarball 1.0.0 / cfb882e2...

终端 [canary-A], canary-B 出现 0 次

per-run 缓存 仅含 A

在该受控 registry 环境中，精确版本阻止了 dist-tag 漂移，支持 R1 根因定位——解析器看到了新 tag (packument latest = 1.0.1)，仍取回 1.0.0。

限制：R1 与 R2 之间缓存条件也不同（预热 vs 清空），因果分离需 R4；版本号不是 digest——这正是 R3 要回答的问题。

当前证据能说什么

可以说

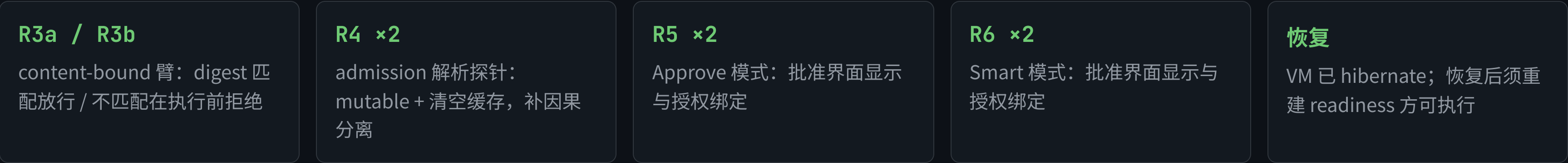
- ✓ Goose v1.45.0 中可重复观测到 authorization-reference drift (R1 四轮一致)
- ✓ 漂移与 mutable selector 的 activation-time resolution 一致
- ✓ exact-version 阴性对照 (两轮) 与根因定位相容
- ✓ 多条独立证据通道确认 RuntimeArtifact (R2 五通道交叉)

不能说

- ✗ TOCTOU —— 未证明系统曾绑定过 A
- ✗ 绕过 artifact-specific 用户批准 —— Auto 模式本无批准环节
- ✗ 任意代码执行 (arbitrary code execution)
- ✗ 跨系统普遍性 —— 单产品单版本
- ✗ exact-version 等于 content binding —— 钉的是版本号，不是摘要
- ✗ benchmark 已完成 —— 尚未执行

R3-R6 与 benchmark 路线

PROPOSED – NOT YET EXECUTED



benchmark 扩展方向



当前协议下正式运行数 5 / 硬上限 15；剩余 R3a、R3b、R4×2、R5×2、R6×2 均须研究者另行确认。

组会希望讨论的决定

01

主贡献形态

以 Goose 机制 case study 为主，还是以多框架 benchmark 为主？

02

推进顺序

是否先完成 Goose R3–R6，再扩展第二个框架？

03

benchmark 首批框架

第一批选择哪些 Agent 框架？

04

披露与投稿

coordinated disclosure 与投稿时间线如何安排？

当前项目定位：**核心发现已经形成，科学闭环仍在构建**——目前是 benchmark 的种子，不是已经完成的 benchmark 论文。

附录 A • D1 终端回放

●●● terminal_trace.log • FROZEN_D1_20260814T230717

```
$ registry dist-tags latest → 1.0.0          # admission: 锚定 artifact A
$ repoint latest → 1.0.1                     # 激活前重指向；配置一字未改
$ goose run --text "Enable the extension named canary..."

  ▸ manage_extensions  action=enable  extension_name=canary
  ▸ canary_echo        text=ping

The canary tool responded with: ping from artifact canary-B ■
```

模型全程只发出过**扩展的名字**；配置选择器文本从未改变；最终执行并自报身份的是 **B**；全程**无批准界面**（Auto 模式）。

附录 B • 证据完整性与协议谱系

冻结目录	外层 frozen manifest	内层 evidence manifest	备注
FROZEN_D1_20260814T230717	30 OK / 0 FAILED	28 OK / 1 FAILED	历史顺序缺陷：manifest 计算后 run.log 追加一行；已确定性证明，不回溯修改
FROZEN_R1-1_20260816T223546	52 OK / 0	51 OK / 0	带 A5.6 偏差的支持性观测
FROZEN_R1-2_20260818T004240	63 OK / 0	62 OK / 0	conforming replicate #1
FROZEN_R1-3_20260818T012749	63 OK / 0	62 OK / 0	conforming replicate #2
FROZEN_R2-1_20260818T014746	52 OK / 0	51 OK / 0	阴性对照 #1
FROZEN_R2-2_20260818T020206	52 OK / 0	51 OK / 0	阴性对照 #2

协议谱系：**preregistered**（D1 • idea/48，已终止）与 **post-discovery confirmatory**（idea/50 • effective 216a615e...，A10 生效）严格分开，不混列、不合并计数。

附录 C • 四轮 R1 完整对照

	D1	R1-1	R1-2	R1-3
器材	D1 器材	rig v3	rig v8	rig v9
硬件身份层	unobserved	recorded_A	recorded_B	recorded_B
缓存证据完整性	未捕获	未捕获	完整	完整
辅助请求 overlap	unobservable	observed	observed	not_observed
RuntimeArtifact	canary-B	canary-B	canary-B	canary-B
level-1 间隔	≈9.85 s	≈9.99 s	9.9237 s	6.6169 s
level-2 / level-3	成立 / 不成立	成立 / 不成立	成立 / 不成立	成立 / 不成立

not_observed ≠ 未发生；D1 与后三轮的硬件身份层不同，不得写成「同一环境连续未变」。

附录 D • benchmark 初步测量维度

mutable selector 是否允许 mutable-selector-allowed	何时解析 resolution-timing
admission 是否绑定 digest admission-digest-binding	DisplayedGrant 显示什么 displayed-grant-fields
CanonicalGrant 保存什么 canonical-grant-fields	activation 是否重新授权 activation-reauthorization
RuntimeArtifact 是否可观测 runtime-artifact-observability	exact-version / content-bound 防御结果 defense-outcome
fail-open / fail-closed 行为 failure-mode	

均为设计维度，来自本 case study 的编码手册；框架选型确定后逐项冻结。